

Cirque Corporation

System Testing and Acceptance Procedure

Document ID: IS-CIRQ-PR-018-G

Category: IT Security Related

Division: Procedure

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: IT Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to define the systematic process for testing and formally accepting information systems, applications, firmware, and hardware designs before their deployment into the production environment. This procedure ensures that systems meet predefined functional, performance, and, critically, security requirements, thereby minimizing risks to Cirque's information assets, in accordance with IS-CIRQ-P-012-G: Secure System Acquisition, Development and Maintenance Policy and ISO/IEC 27001:2022 Annex A.8.29.

****2. Scope****

2. Scope

This procedure applies to all new information systems, applications (including commercial off-the-shelf - COTS, in-house developed, or customized), significant upgrades, major configuration changes, and new firmware or hardware designs (e.g., ASIC designs developed with ****Cadence****) prior to their release or deployment into Cirque's

production environment.

****3. Definitions****

3. Definitions

- ****User Acceptance Testing (UAT):**** Testing performed by end-users or business representatives to verify that the system meets business requirements.
- ****Security Testing:**** Testing specifically focused on identifying vulnerabilities and verifying the effectiveness of security controls.
- ****Vulnerability Scan:**** An automated test to identify known vulnerabilities in systems, applications, or networks.
- ****Penetration Test:**** A simulated attack against a system, application, or network to evaluate its security.

****4. Responsibilities****

4. Responsibilities

- ****Project Manager/System Owner:**** Overall responsible for ensuring that systems undergo appropriate testing and meet acceptance criteria.
- ****Development Teams:**** Responsible for developing testable code/designs, addressing identified issues, and supporting testing activities.
- ****IT Manager/Security Personnel:**** Responsible for defining security testing requirements, overseeing security tests, and evaluating security test results.
- ****End-Users/Business Owners:**** Responsible for participating in UAT

and providing feedback on system functionality.

****5. Procedure****

5. Procedure

****5.1. Test Environment Preparation**** a. A dedicated test environment, logically and (where practical) physically separated from the production environment, shall be prepared for testing. b. The test environment shall replicate the production environment as closely as possible in terms of hardware, software, and network configuration. c. Test data shall be used, which must not contain actual sensitive production information unless adequately anonymized or sanitized. d. Access to the test environment shall be restricted to authorized testing and development personnel.

****5.2. Test Planning**** a. A comprehensive test plan shall be developed, outlining: * Test objectives (functional, performance, security). * Test cases and scenarios. * Roles and responsibilities for testing. * Required test data. * Test schedule. * Criteria for successful completion of tests. * Procedures for documenting and tracking defects. b. ****Security Test Plan:**** A specific section of the test plan shall address security testing, including: * Vulnerability scanning targets and scope. * Specific security features to be tested (e.g., authentication, authorization, input validation, encryption). * Types of security tests to be conducted (e.g., code review, SAST, DAST, penetration testing).

****5.3. Test Execution****

****5.3.1. Functional and Integration Testing:**** a. Development teams shall conduct unit, integration, and system testing to ensure the system functions as designed and integrates correctly with other systems.

5.3.2. Security Testing: a. **Vulnerability Scanning:** Systems and applications shall undergo automated vulnerability scanning to identify common security weaknesses. * For in-house developed software, SAST tools integrated with **GitLab CI/CD** (as per IS-CIRQ-PR-017-G) should be leveraged. * For web applications, DAST tools should be utilized. b. **Penetration Testing:** Critical systems (e.g., those handling sensitive data, external-facing applications, core infrastructure) shall undergo internal and/or external penetration testing by qualified personnel (internal or third-party). c. **Configuration Review:** Security configurations of the system, including operating system, database, and application settings, shall be reviewed against hardening baselines. d. **Access Control Testing:** Verification that access controls function as intended, enforcing the principle of least privilege. e. **Cryptography Testing:** If cryptographic controls are implemented, verify their correct usage and strength (e.g., certificate validity, algorithm strength). f. **ASIC/Firmware Security Testing (for Cadence designs):** Specific tests for hardware vulnerabilities (e.g., side-channel analysis, fault injection) shall be conducted where applicable, alongside firmware integrity checks.

5.3.3. User Acceptance Testing (UAT): a. End-users and business owners shall conduct UAT to ensure the system meets business requirements and is suitable for operational use.

5.4. Defect Management and Remediation a. All identified defects and vulnerabilities shall be formally documented, tracked, and prioritized based on their severity and impact. b. Critical and high-severity security vulnerabilities must be remediated promptly before deployment. c. Remediation actions shall be re-tested to confirm effectiveness.

5.5. System Acceptance a. A system can only be accepted for deployment into the production environment if: * All critical and

high-severity defects and vulnerabilities have been remediated or formally accepted by the IT Manager and relevant business owner with an approved mitigation plan and residual risk acceptance. * All security requirements outlined in the design phase have been met and verified by security testing. * UAT has been successfully completed, and business owners approve the system for release. b. Formal sign-off for acceptance shall be obtained from the IT Manager and relevant business owner(s).

****5.6. Documentation and Handover**** a. All testing results, defect logs, and acceptance documents shall be archived. b. Updated system documentation, including security configurations, operational procedures, and user manuals, shall be prepared and handed over to the operations team (refer to IS-CIRQ-PR-006-G: Document Control Procedure).

****6. Review and Update****

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's system development lifecycle, testing tools, or regulatory requirements.

****7. Related Documents****

7. Related Documents

- IS-CIRQ-P-012-G: Secure System Acquisition, Development and Maintenance Policy
- IS-CIRQ-PR-017-G: Secure Development Procedure
- IS-CIRQ-P-011-G: Operations Security Policy
- IS-CIRQ-PR-013-G: Change Management Procedure
- IS-CIRQ-F-001-G: Risk Assessment Register

- IS-CIRQ-PR-006-G: Document Control Procedure